

Marco Integrativo GQM + PRAGMATIC para Indicadores CWE a Nivel Nacional

1. Introducción

Este marco integra la metodología **GQM (Goal-Question-Metric)** con la evaluación **PRAGMATIC** de métricas para diseñar y gobernar indicadores nacionales basados en CWE (Common Weakness Enumeration), desde objetivos estratégicos de país hasta datos técnicos recogidos en las organizaciones. [web:16][web:17][web:18]

La lógica es sencilla, aunque no por ello menos testaruda:

- Primero se fijan metas (Goal) a nivel nacional y sectorial.
- Después se formulan preguntas (Question) que permitan comprobar si avanzamos hacia esas metas.
- Finalmente se definen métricas (Metric) basadas en CWE, CVE, CVSS y otros datos técnicos. [web:16][web:24]

Cada métrica se valora con los criterios PRAGMATIC (Predictive, Relevant, Actionable, Genuine, Meaningful, Accurate, Timely, Independent, Cost-effective) para asegurarnos de que no estamos midiendo por deporte, sino por utilidad. [web:21][web:26]

2. Resumen de la metodología GQM

La metodología GQM plantea tres niveles: [web:17][web:18][web:25]

1. Goal (Meta)
2.
¿Qué queremos lograr, desde qué punto de vista y sobre qué objeto (país, sector, programa)?
3.
Question (Pregunta)
4.
¿Qué debemos saber para juzgar si estamos logrando esa meta?
5.
Metric (Métrica)
6. ¿Qué observables medimos para responder a las preguntas de forma objetiva?
¿Qué queremos lograr, desde qué punto de vista y sobre qué objeto (país, sector, programa)?
Question (Pregunta)
¿Qué debemos saber para juzgar si estamos logrando esa meta?

Metric (Métrica)

Aplicado a indicadores CWE a nivel nacional, los **objetos** de medición incluyen:

- Programas nacionales de ciberseguridad.
 - Sectores críticos (sanidad, energía, administración pública, etc.).
 - El “perfil de debilidades” del software y hardware desplegado en el país, usando CWE, CVE y CVSS.
- [web:22][web:28][web:9]

3. Resumen del metamodelo PRAGMATIC

El enfoque PRAGMATIC es un metamétrica para evaluar la calidad de las métricas de seguridad:

[web:21][web:26]

- P – Predictive (Predictivo): ayuda a anticipar resultados futuros.
- R – Relevant (Relevante): está alineada con objetivos de negocio/país.
- A – Actionable (Accionable): sugiere acciones concretas.
- G – Genuine (Genuino): refleja la realidad, no sirve para maquillarla.
- M – Meaningful (Significativo): se entiende y tiene sentido para decisores.
- A – Accurate (Preciso): suficientemente exacta para el uso previsto.
- T – Timely (Oportuno): disponible cuando se necesita.
- I – Independent (Independiente): no está sesgada por quien la produce.
- C – Cost-effective (Rentable): el coste de obtenerla es razonable.

En este marco asignaremos a cada métrica una valoración cualitativa (Alto / Medio / Bajo) y, si se desea, un puntaje numérico (por ejemplo, 0–3 por criterio, sumando un “score PRAGMATIC”).

4. Conjunto de metas nacionales (G de GQM)

Inspirándonos en el informe de indicadores CWE propuesto para España y alineado con estrategias europeas y nacionales, planteamos cuatro metas principales: [web:9][web:14][web:13][web:22][web:28]

G1 – Reducir la prevalencia nacional de debilidades críticas CWE

Formulación GQM

- Objetivo: Reducir la prevalencia de debilidades de software y hardware clasificadas en CWE, en especial las recogidas en el Top 25 y las listas KEV/MIHW, en sistemas relevantes para el país. [web:28]
- [web:22][web:9]
- Perspectiva: Nacional / sectorial.
 - Motivo: Mejorar la resiliencia, reducir incidentes y alinearse con buenas prácticas internacionales.

G2 – Mejorar la capacidad nacional de detección y remediación de debilidades CWE

Formulación GQM

- Objetivo: Reducir sistemáticamente el tiempo de detección y remediación de debilidades agrupadas por CWE en organizaciones clave. [web:9][web:14]
- Perspectiva: Nacional, con énfasis en operadores esenciales y administración.

- Motivo: Minimizar ventana de exposición, especialmente para debilidades asociadas a vulnerabilidades explotadas activamente (KEV). [web:2][web:9]

G3 - Integrar CWE en el gobierno, la regulación y los marcos de cumplimiento

Formulación GQM

- Objetivo: Lograr que los marcos regulatorios (ENS, NIS2, guías nacionales) y los sistemas de gobierno corporativo utilicen CWE como lenguaje estándar para debilidades. [web:9][web:13][web:22]
- Perspectiva: Reguladores, responsables políticos, alta dirección de organizaciones.
- Motivo: Alinear el discurso técnico con obligaciones legales y políticas públicas.

G4 - Desarrollar capacidades y cultura nacional en torno a CWE

Formulación GQM

- Objetivo: Aumentar la capacidad técnica (formación, herramientas, procesos) y la cultura organizativa alrededor de CWE, para que la gestión de debilidades no sea un deporte extremo reservado a unos pocos expertos. [web:8][web:9][web:14]
- Perspectiva: Ecosistema de talento, proveedores, sector público y privado.
- Motivo: Sostenibilidad de la mejora a largo plazo.

5. GQM aplicado a indicadores CWE propuestos

A continuación se presenta una selección de indicadores clave del informe CWE original, ahora estructurados en forma GQM.

5.1. Indicadores de prevalencia (meta G1)

5.1.1. G1Q1 - ¿Qué proporción de vulnerabilidades nacionales se explican por debilidades CWE del Top 25?

- Métrica M1.1: Porcentaje de vulnerabilidades (CVE u otras entradas equivalentes en repositorios nacionales) mapeadas a algún CWE del Top 25 vigente. [web:28][web:1][web:4]
- Definición:
Numerador: número de entradas de vulnerabilidad con mapeo a $CWE \cap Top\ 25$.
Denominador: total de vulnerabilidades registradas en el periodo.
- Fuente de datos: CSIRTs nacionales, repositorios sectoriales, NVD cuando aplique. [web:28][web:27][web:9]
- Numerador: número de entradas de vulnerabilidad con mapeo a $CWE \cap Top\ 25$.
- Denominador: total de vulnerabilidades registradas en el periodo.

5.1.2. G1Q2 - ¿Cómo se distribuyen las debilidades CWE por sector?

- Métrica M1.2: Distribución porcentual de vulnerabilidades por categoría CWE Top 25 en cada sector (sanidad, energía, AP, etc.). [web:9][web:14][web:28]
- Métrica M1.3: Ranking de las 10 CWE más frecuentes por sector.

5.1.3. G1Q3 – ¿Las debilidades de diseño vs. implementación evolucionan en sentido deseado?

- Métrica M1.4: Proporción de debilidades de diseño (según clasificación CWE-1000) frente a debilidades puramente de implementación. [web:7][web:22]

5.2. Indicadores de criticidad y riesgo (meta G1 / G2)

5.2.1. G1Q4 – ¿Cuál es la severidad media de las vulnerabilidades asociadas a determinadas CWE?

- Métrica M2.1: CVSS medio por CWE en activos nacionales, calculado sobre las vulnerabilidades reportadas. [web:9][web:14][web:28]

5.2.2. G2Q1 – ¿Qué peso tienen las debilidades asociadas a vulnerabilidades explotadas activamente (KEV)?

- Métrica M2.2: Porcentaje de vulnerabilidades asociadas a CWE presentes en el catálogo KEV (Top KEV o total KEV) sobre el total de vulnerabilidades. [web:2][web:9]

5.3. Indicadores de desempeño (meta G2)

5.3.1. G2Q2 – ¿Qué tiempo tardan las organizaciones en corregir debilidades CWE críticas?

- Métrica M3.1: Tiempo medio de remediación (en días) de vulnerabilidades asociadas a determinadas CWE prioritarias (por ejemplo, Top 10 KEV/CWE). [web:2][web:9][web:14]

5.3.2. G2Q3 – ¿Las acciones de mitigación tienen algún efecto visible?

- Métrica M3.2: Variación interanual del volumen de vulnerabilidades por CWE prioritaria en organizaciones objetivo. [web:1][web:28][web:9]

5.4. Indicadores de madurez y adopción de CWE (meta G3 / G4)

5.4.1. G3Q1 – ¿Hasta qué punto CWE está incorporado en normas, contratos y auditorías?

- Métrica M4.1: Porcentaje de pliegos de contratación TIC públicos que incluyen referencias a CWE como taxonomía o al Top 25 como lista de referencia.
- Métrica M4.2: Porcentaje de auditorías ENS/ISO/NIS2 que incluyen evaluación explícita del tratamiento de debilidades clasificadas por CWE. [web:9][web:13][web:22]

5.4.2. G4Q1 – ¿Cuál es el grado de integración de CWE en los procesos internos de las organizaciones?

- Métrica M4.3: Porcentaje de organizaciones que utilizan CWE como taxonomía formal en sus repositorios de vulnerabilidades.
- Métrica M4.4: Porcentaje de organizaciones que mapean sistemáticamente vulnerabilidades a CWE (preguntas de encuesta 3.2 y 3.3 del cuestionario).

5.4.3. G4Q2 – ¿Cómo evoluciona la capacidad de detección frente a CWE prioritarias?

- Métrica M4.5: Porcentaje de herramientas de análisis (SAST/DAST) empleadas por las organizaciones que soportan y reportan CWE, sobre el total de herramientas usadas en el panel. [web:22][web:11]

6. PRAGMATIC aplicado a las métricas CWE

Para cada métrica, se propone una evaluación cualitativa inicial según PRAGMATIC, que podrá ajustarse con experiencia real.

Como ejemplo, para algunas métricas:

M1.1 – % de vulnerabilidades nacionales mapeadas a CWE del Top 25

- P (Predictivo): Alto – cambios en esta métrica anticipan la evolución de riesgo estructural.
- R (Relevante): Alto – directamente alineado con G1.
- A (Accionable): Medio-alto – permite orientar políticas de mitigación sobre debilidades frecuentes.
- G (Genuino): Medio – depende de la calidad del mapeo CWE en las fuentes. [web:28][web:22]
- M (Significativo): Alto – comprensible para decisores (“concentración del riesgo”).
- A (Preciso): Medio – precisión condicionada por la exhaustividad de los registros. [web:27][web:9]
- T (Oportuno): Medio – depende de la cadencia de reporte (mensual, trimestral...).
- I (Independiente): Medio – el dato lo generan actores que también son evaluados.
- C (Rentable): Medio-alto – requiere cierta inversión en integración de datos, pero escala bien.

M3.1 – Tiempo medio de remediación por CWE prioritaria

- P: Alto – buena capacidad para anticipar ventana de exposición.
- R: Alto – directamente alineado con la mejora de respuesta (G2). [web:9][web:14]
- A: Alto – señala dónde acelerar procesos, ajustar SLAs, etc.
- G: Medio-alto – las fechas de descubrimiento y cierre suelen estar registradas, aunque con ruido.
- M: Alto – la idea de “días hasta parchear” es muy intuitiva.
- A (Preciso): Medio – depende de la definición uniforme de hitos (detección, notificación, cierre).
- T: Medio – calculable casi en tiempo real si las herramientas están integradas.
- I: Medio – riesgo de “forzar” cierres administrativos para mejorar números.
- C: Medio – requiere cierto esfuerzo de integración, pero utilizable durante años.

En el fichero (b) se plasma esta evaluación de manera sistemática para el conjunto de métricas.

7. Uso operativo del marco GQM + PRAGMATIC

7. Definir o revisar las metas nacionales (G) aceptadas por los responsables políticos y técnicos.
8. Validar el conjunto de preguntas (Q) para asegurar que cubren esas metas sin redundancia innecesaria.
9. Seleccionar las métricas (M) que sean PRAGMATICamente más sólidas, descartando las que puntúan bajo de forma sistemática. [web:21][web:26][web:24]
10. Construir cuadros de mando que preserven la trazabilidad: cada gráfico debe poder remontarse a su Q y G.
11. Revisar periódicamente el conjunto de métricas a la luz de la experiencia y de cambios en CWE (metodologías Top 25, nuevos MIHW, etc.). [web:28][web:22]

Si todo va bien, al cabo de unos años tendremos menos indicadores decorativos y más métricas que sirvan para tomar decisiones incómodas, que son generalmente las únicas que mueven la aguja.